

Joseph Gonzales

84-L02_B03_Group_R_Assignment

 Paper 8

Document Details

Submission ID

trn:oid:::3618:151270072

Submission Date

Sep 10, 2026, 7:47 PM GMT+8

Download Date

Sep 10, 2026, 7:50 PM GMT+8

File Name

84-L02_B03_Group_R_Assignment.pdf

File Size

618.3 KB

23 Pages

5,061 Words

33,085 Characters

*% detected as AI

AI detection includes the possibility of false positives. Although some text in this submission is likely AI generated, scores below the 20% threshold are not surfaced because they have a higher likelihood of false positives.

Caution: Review required.

It is essential to understand the limitations of AI detection before making decisions about a student's work. We encourage you to learn more about Turnitin's AI detection capabilities before using the tool.

Disclaimer

Our AI writing assessment is designed to help educators identify text that might be prepared by a generative AI tool. Our AI writing assessment may not always be accurate (it may misidentify writing that is likely human generated as AI generated and likely AI generated as human generated) so it should not be used as the sole basis for adverse actions against a student. It takes further scrutiny and human judgment in conjunction with an organization's application of its specific academic policies to determine whether any academic misconduct has occurred.

Table of Contents

Table of Contents	i
Table of Figures	i
List of Tables	ii
1.0 Executive Summary	1
2.0 Scope & Obligations	2
2.1 Scope of Assessment	2
2.2 Data Types and Applicable Obligations	2
2.3 Applicable Standards and Laws	3
2.4 PDPA Obligations	3
2.5 Cloud Security and Shared Responsibility	4
3.0 Providers & Shared-Responsibility Assessment	4
4.0 SLA Analysis	6
4.1 Gap Summary	7
5.0 Data-privacy & Integrity Assessment	8
5.1 Technical Evidence Register	8
6.0 Gaps & Remediation Plan	12
7.0 Conclusion & Recommendation	14
7.1 Conclusion	14
7.2 Recommendation	14
7.3 Final Decision	15
8.0 References	15
9.0 Appendices	16
9.1 Appendix A - Group Declaration & Peer-Contribution Form	16
9.2 Appendix B - Technical Evidence Pack	17
9.3 Appendix C - Collection Script	20

Table of Figures

Figure 1: Screenshot of Evidence Collection	17
Figure 2: Continuation Screenshot of Evidence Collection with the SHA256	17

List of Tables

Table 1: Applicable Standards and Laws	3
Table 2: Providers & Shared-Responsibility	4
Table 3: Gap Summary	7
Table 4: Technical Evidence Register	8
Table 5: Prioritised Gaps & Remediation Plan	12
Table 6: Recommendation Table	14
Table 7: Group Declaration & Peer-Contribution	16
Table 8: Script of Evidence Collection	20

1.0 Executive Summary

Recommendation: Adopt with Conditions. MediPay Sdn Bhd should proceed with the proposed public cloud migration only after the main security and compliance gaps are resolved. MediPay operates a multi-tenant Software-as-a-Service (SaaS) platform for clinics in Malaysia and handles payment-card data and patient health information (PHI). Therefore, the cloud environment must support MediPay's obligations under PCI DSS, the amended PDPA, ISO/IEC 27017, ISO/IEC 27018 and the CSA Cloud Controls Matrix (CCM).

The assessment identified several important findings. First, the breach-notification SLA is not specific enough, as the provider only commits to notifying MediPay "without undue delay". This may affect MediPay's ability to meet the 72-hour PDPA notification requirements. Second, data residency is a concern because some backup services may replicate data across regions unless this is disabled. Third, the shared responsibility model means MediPay remains responsible for important controls such as patient-data access, application security, and encryption-key management.

The analysis has also revealed weaknesses in encryption keys managed by the customer, production logging, audit rights, availability safeguards, and deletion evidence. Such weaknesses may pose risks in terms of privacy, compliance, cost, and operations. Hence, the board needs to approve the migration on condition that MediPay finishes the prioritized remediation work and validates P1 critical and P2 high risks prior to production. Where controls are not verifiable, MediPay should seek certification or audit rights for validation purposes.

2.0 Scope & Obligations

2.1 Scope of Assessment

The current assessment will evaluate the suitability of the proposed cloud environment in protecting the confidentiality, integrity, and privacy of the information held by MediPay Sdn Bhd. MediPay Sdn Bhd offers services to the medical clinics in Malaysia and has two types of critical data – Payment card information used for billing and Patient Health Information (PHI).

Security risks associated with multi-tenant cloud will be evaluated for making sure that the data of different medical clinics are protected and the security responsibilities are shared among MediPay and cloud provider. The relevant laws, regulations, and standard practices are considered.

Additionally, the SLA obligations, data residency, cross-border transfer of data, notification of any data breaches, data protection measures, data disposition requirements, and technical evidence are covered in the current assessment.

2.2 Data Types and Applicable Obligations

MediPay's cloud-based SaaS offering involves two primary types of sensitive data. One is payment card data for clinic billing purposes and other is personal information pertaining to patients. The payment card data must adhere to the PCI DSS requirements, while the patient and personal information is subject to the Personal Data Protection Act 2010 and the Personal Data Protection (Amendment) Act 2024.

ISO/IEC 27018 is important for MediPay because it provides guidelines on how to protect personal information in the public cloud environment. ISO/IEC 27017 is also relevant for the same reasons; it provides cloud security guidelines and establishes responsibilities of each party within the cloud model.

Given that MediPay operates a multi-tenant SaaS offering, controls are needed to prevent access or exposure of data belonging to one clinic by another. This implies that there should be a clearly defined responsibility division concerning security and privacy in order for all the required controls to be implemented.

2.3 Applicable Standards and Laws

Table 1: Applicable Standards and Laws

Standard / Law	Requirement	Application to MediPay
PCI DSS	Protects payment-card data during storage and processing.	MediPay must protect payment-card data used for clinic billing.
ISO/IEC 27017	Provides security guidance for cloud services.	Helps MediPay understand the security responsibilities of the cloud provider and MediPay.
ISO/IEC 27018	Provides guidance for protecting personal information in public clouds.	Helps MediPay protect patient and other personal information in the cloud.
PDPA 2010, as amended in 2024	Requires organisations to protect personal data and follow requirements such as breach notification, DPO, data portability, processors and cross-border transfers.	MediPay must protect patient and personal data and ensure the cloud provider supports these requirements.
CSA Cloud Controls Matrix (CCM)	Provides a framework for cloud security controls and responsibilities.	Helps MediPay assess security controls and identify which controls are handled by MediPay or the cloud provider.

The mentioned standards and laws above are what will ensure the data security at MediPay. It is necessary to include the above-mentioned standards and laws while evaluating the cloud service offered by MediPay.

2.4 PDPA Obligations

The PDPA 2010 works together with the Personal Data Protection (Amendment) Act 2024 to safeguard MediPay since it holds medical records and personal identification details of its clients. These changes have become effective from 1 June 2025. This corporation has introduced five important requirements which include personal data breach notification and appointment of Data Protection Officer (DPO).

It has to notify any personal data breach meeting the specified criteria to the Personal Data Protection Commissioner within 72 hours after being notified about the breach. In addition, affected individuals need to be notified within seven days. The cloud service provider should run security monitoring systems that will detect all the incidents and will provide instant notifications of the data breach. The board of MediPay established these conditions to guarantee they can track data breaches properly while maintaining complete control over their data storage locations. The assessment process requires MediPay to assess the cloud service provider's Service Level Agreement (SLA) and data storage locations and their system for allocating responsibilities between parties according to PDPA standards.

2.5 Cloud Security and Shared Responsibility

The assessment uses the shared responsibility model because both the cloud provider and MediPay have security responsibilities. The cloud provider must safeguard the cloud infrastructure together with its platform, but MediPay must defend its applications and data and maintain user access control and configuration settings.

MediPay needs to identify which security controls are handled by the provider, and which controls must be handled by MediPay. The organisation needs to define roles properly because undefined roles will generate security flaws, which will also cause compliance problems.

The assessment will use the provider's CSA STAR/CAIQ evidence and technical evidence to check whether the required security controls are properly implemented. The system will identify which security controls belong to the provider and which ones follow MediPay's management structure.

There should be additional evidence provided by the organisation where verification controls cannot be verified directly through the request from MediPay. The additional evidence will serve as audit evidence or certification. It will ensure that MediPay protects its cloud services while meeting its compliance requirements.

3.0 Providers & Shared-Responsibility Assessment

As the cloud provider in our assessment, AWS was used based on information provided in the Customer Agreement from AWS and its self-assessment for CSA STAR Level 1 compliance (CAIQ v4), together with ISO/IEC 27017 and 27018 certification scope. Since the board of MediPay did not provide an alternative proposal, this serves as a practical evidence-based choice. In case your team opts for another provider, such as Azure, Google Cloud, or any other hosted in Malaysia, the format remains the same – only CAIQ questions answered and certification scope changes.

Cloud security is based on a shared responsibility approach, where the cloud provider is responsible for security of the underlying infrastructure and the customer is responsible for security of its own data stored within the infrastructure. In a multi-tenant SaaS platform as that of MediPay, this division of responsibility is more complex and can be seen in the following format tailored to PCI DSS and amended PDPA.

Table 2: Providers & Shared-Responsibility

Control area	Who is responsible	Why
Physical data centre security	Provider	MediPay never touches the physical facility
Network perimeter for	Provider	Part of the underlying infrastructure

the region		
Encryption at rest (capability)	Provider	KMS and storage-layer encryption are built and offered by default
Encryption key policy and rotation	Shared	Provider runs the KMS, MediPay must choose a customer-managed key and enforce its use
Patient record access control (IAM roles)	Customer	Only MediPay knows which roles should see which patient data
Application code and cardholder data flow	Customer	MediPay owns the SaaS application logic
OS and hypervisor patching	Provider	Below the line MediPay can see or touch
MediPay application patching	Customer	MediPay's own codebase
Incident notification to MediPay	Provider (contractual duty)	Provider must tell MediPay something happened, see Section 5 gap on timing
Notification to the Commissioner within 72 hours	Customer	The amended PDPA places this duty on MediPay as the data controller, not on the provider
DPO appointment and registration	Customer	Purely an organisational obligation, the provider has no role in it

MediPay gets some initial indication of the capabilities that the provider asserts to offer as per the CAIQ self-assessment questions for instance in the domain CEK for the capability of encryption, in the domain LOG for the capability of logging hooks, and in the domain IAM for identity federation. However, the responses to the CAIQ questionnaire are done by the provider themselves, without verification by an independent party. We treat such answers as hypotheses and used our LocalStack evidence pack in Section 6 to confirm the behaviour of the alleged controls.

Critical finding: the controls which directly determine whether MediPay meets PCI DSS 3.5.1 encryption requirement and 72-hour Commissioner notification requirement from the amended PDPA lie in the shared/customer columns, not the provider columns. The provider offers the necessary capabilities in the form of KMS, IAM, logging, and MediPay is responsible for complying with them. This is the critical finding which our evidence pack in Section 6 is designed to prove, and this is the gap which the remediation plan in Section 7 needs to close.

4.0 SLA Analysis

The standard SLA provided by the vendor was analyzed taking into account the six aspects specified by the board of directors to review in connection with the availability of services, security, breach notification, data location, audit rights, and data return/deletion on termination. Analysis results are presented below:

- **Availability**

The SLA assures the availability of the provider's services at 99.9% per month and provides service credits as the sole remedy for unavailability. However, the said credits are capped to a certain percentage of fees and will not cover the revenue loss of the clinic from its clients during the downtime period.

- **Security & breach-notification terms**

The SLA promises the provider compliance with the ISO 27001, 27017 and 27018 certification standards and reporting MediPay about a security event that concerns its data "without undue delay." The latter is the critical aspect here as it does not specify any time limit expressed in hours. In case if the process of identifying and reporting takes a couple of days in the provider's office, MediPay would not be able to report the incident to the Commissioner within 72 hours.

- **Data location and residency**

This is because the provider allows MediPay to lock down their data to a specific region which, in reality, is the Asia Pacific (Singapore) due to lack of a regional option in the country at the time of writing. Nevertheless, some resiliency and backup services provided by the provider copy the data between regions unless the customer disables that function explicitly. This scenario constitutes a residency issue under the reformed cross-border transfer test of the PDPA and not merely a technical challenge.

- **Audit rights**

The SLA provides access by the MediPay to the CSA STAR report and SOC 2 Type II report, but does not provide to the MediPay, or to an independent assessor representing the MediPay, an independent audit right. When an assessor of the PCI DSS expects to have direct validation of the control's environment, being given a certificate to read is less powerful than having an audit right. This is true in virtually any of the major public cloud agreements; thus, this is an industry-wide issue that has nothing to do with this particular RFP, but should still be identified as a gap.

- **Data return and deletion on exit**

The obligation of the provider includes exporting the data of MediPay for 30 days after the contract ends, and deleting the data within 90 days after the period of data exportation ends. Such a schedule is acceptable. What is not included in the obligations of the provider is providing MediPay with a certificate of deletion. This certificate will provide a document that MediPay can present to the PDPA auditor or the Commissioner to prove that the data has been deleted.

4.1 Gap Summary

The table below consolidates the five gaps identified above. Risk ratings feed directly into the prioritised remediation plan in Section 7.

Table 3: Gap Summary

SLA element	MediPay requirement	Provider commitment	Gap identified	Risk
Availability	Uptime sufficient for a billing-critical SaaS platform	99.9% monthly uptime, service credit as sole remedy	Credits are capped as a percentage of fees and do not cover a clinic's lost billing revenue during an outage	Medium
Breach notification	Notification fast enough for MediPay to meet its own 72-hour Commissioner deadline	"Without undue delay", no fixed number of hours stated	A vague timeframe could cause MediPay to breach its own statutory deadline through no fault of its own process	High
Data residency	Patient data confined to one named region, no unannounced cross-border movement	Region is selectable, but default backup replication for some services can cross regions unless explicitly disabled	Possible unauthorised cross-border transfer under the PDPA's reformed transfer test	High
Audit rights	Ability to independently verify the provider's control environment	STAR and SOC 2 Type II report available on request, no on-site or independent technical audit right	MediPay's PCI DSS assessor cannot independently validate the provider, only read its self-reported certificates	Medium
Exit and deletion	Certified, timely deletion of all patient and card data on exit	Data available for export 30 days post-termination, deleted within 90 days after that, including backups	No deletion certificate is offered, so MediPay has no documentary proof of deletion to show an auditor or the Commissioner	Medium

5.0 Data-privacy & Integrity Assessment

5.1 Technical Evidence Register

Eight control measures help achieve the following defensive layers that satisfy the basic requirements of MediPay:

- **Confidentiality:** Patients' and payments' data is protected through storage layer encryption (CEK-03), tenant isolation between clinics (IVS), and strict protection from public bucket exposure (DSP-17).
- **Integrity:** The integrity of system operations is achieved due to the enforcement of least privilege access (IAM-05) and automated pipeline security gates (AIS-06) as well as logging of all administrative activities through a hash-verified audit log (LOG-07).
- **Privacy & Compliance:** The control measures comply with the requirements of PDPA and ISO/IEC 27018 through automatic classification of sensitive records (DSP-04) and data minimization policy for 90 days (DSP-16).

Table 4: Technical Evidence Register

No	Obligation	CCM Control ID	Responsibility	Verification Method	Evidence and Date
1	PCI DSS v4.0 Req. 7.2.2 System access is restricted to least privileges necessary.	IAM-05	Customer MediPay owns the SaaS application logic and must define the IAM roles.	echo "=== IAM-05 (policy contents) ===" aws \$EP iam get-role-policy --role-name patient-lookup-role --policy-name PatientLookupReadOnly 3	"RoleName": "patient-lookup-role", "PolicyName": "PatientLookupReadOnly", "PolicyDocument": { "Version": "2012-10-17", "Statement": [{ "Effect": "Allow", "Action": ["s3:GetObject", "s3:ListBucket"], "Resource": ["arn:aws:s3:::medipay-patient-records",

					"arn:aws:s3:::medipay-patient-records/confidential/*" Collected: Sun Sep 6 09:12:45 PM UTC 2026 by Syed
2	ISO/IEC 27017:2015 Tenant isolation and segmentation of virtualized networks.	IVS-06	Customer MediPay must configure the ABAC condition keys to segregate its clinics.	aws \$EP s3api get-bucket-policy --bucket \$BUCKET --query 'Policy' --output text jq .	{"Version": "2012-10-17", "Statement": [{"Sid": "EnforceTenantIsolation", "Effect": "Deny", "Principal": "*", "Action": "s3:GetObject", "Resource": "arn:aws:s3:::medipay-patient-records/confidential/*", "Condition": {"StringNotEquals": {"s3:ExistingObjectTag/TenantID": "\${aws:PrincipalTag/TenantID}"}}]} Collected: Sun Sep 6 09:27:42 PM UTC 2026 by Syed
3	PCI DSS v4.0 Req. 3.5.1 PAN must be rendered unreadable wherever it is stored.	CEK-03	Shared Provider supplies the KMS; MediPay must configure and enforce it.	aws \$EP s3api get-bucket-encryption --bucket \$BUCKET --query 'ServerSideEncryptionConfiguration.Rules[0]' --output json	{"ApplyServerSideEncryptionByDefault": {"SSEAlgorithm": "aws:kms"}, "BucketKeyEnabled": false, "BlockedEncryptionTypes": {"EncryptionType": ["SSE-C"]}} Collected: Sun Sep 6 09:45:21 PM UTC 2026 by Syed
4	ISO/IEC 27018:2019 PII must be classified to ensure appropriate protection.	DSP-04	Customer Only MediPay knows which records contain PHI or PCI data.	aws \$EP s3api get-object-tagging --bucket \$BUCKET --key confidential/record.txt	{"TagSet": [{"Key": "classification", "Value": "confidential"}]} Collected: Sun Sep 6 09:50:59 PM UTC 2026 by Syed

5	PCI DSS v4.0 Req. 10.2 Audit trails must be implemented for all administrative actions.	LOG-07	Shared Provider logs the API calls; MediPay must secure the audit trail.	docker logs "\$LS_CONTAINER" 2>&1 grep -E "AWS [a-z0-9]+\.[A-Za-z]+ =>" > mgmt-trail.log wc -l mgmt-trail.log sha256sum mgmt-trail.log > mgmt-trail.sha256 aws \$EP s3 cp mgmt-trail.sha256 s3://miit-audit-trail/	129 mgmt-trail.log 37582de5a17824411a7202ed5a416e150514571380aa8def1f34002018acdbcd mgmt-trail.log upload: ./mgmt-trail.sha256 to s3://miit-audit-trail/mgmt-trail.sha256 Collected: Sun Sep 6 10:11:36 PM UTC 2026 by Syed
6	PCI DSS v4.0 Req. 6 Develop and maintain secure systems and software pipelines.	AIS-06	Customer MediPay owns the CI/CD pipeline and deployment gates.	bash ci-gate.sh > /dev/null 2>&1 echo "gate exit code: \$? (0 = policy satisfied, 1 = blocked)"	gate exit code: 0 (0 = policy satisfied, 1 = blocked) Collected: Sun Sep 6 10:28:33 PM UTC 2026 by Syed
7	PDPA 2010 Security Principle Personal data must be protected from loss, misuse, modification, unauthorised or accidental access or disclosure, alteration or destruction.	DSP-17	Customer MediPay must explicitly enable the public access block guardrails.	aws \$EP s3api get-public-access-block --bucket \$BUCKET --query 'PublicAccessBlockConfiguration' --output json	{"BlockPublicAcls": true, "IgnorePublicAcls": true, "BlockPublicPolicy": true, "RestrictPublicBuckets": true} Collected: Sun Sep 6 10:42:03 PM UTC 2026 by Syed
8	PDPA Data Retention	DSP-16	Customer MediPay sets	aws \$EP s3api get-bucket-lifecycle-configuration --bucket \$BUCKET --query	[["AutoDelete90Days", "Enabled"]]

	Personal data must not be kept longer than is necessary.		lifecycle rules to match the 90-day deletion SLA.	'Rules[].[ID, Status]' --output json	Collected: Sun Sep 6 10:57:25 PM UTC 2026 by Syed
--	--	--	---	--------------------------------------	---

6.0 Gaps & Remediation Plan

Although the technical evidence registry is capable of verifying configuration controls, the LocalStack lab environment simply lacks structural capabilities to prove physical security in the data centres, vetting of provider employees, and failover across regions. For those areas, MediPay has no choice but to trust the provider's ISO/IEC 27001 certification and SOC 2 Type II audit report as proof documents.

The below gaps are from two sources, the SLA gap analysis in Section 4.1 and two other gaps identified in the technical evidence register in Section 5.0 each has an owner, a priority and a closure timeline. Priority is based on how directly a gap threatens MediPay's own statutory deadlines under the amended PDPA or PCI DSS, how far the supporting evidence fell short of full assurance, and whether the gap is of a contractual/commercial nature.

Table 5: Prioritised Gaps & Remediation Plan

No	Gap	Source	Risk	Owner	Priority	Timeline	Remediation action
1	Breach notification SLA uses "without undue delay," no fixed hours	SLA (4.1)	High	Legal & Contracts Lead, with DPO sign-off	P1 Critical	Before contract signature	Negotiate a fixed, numeric notification window (e.g. provider must notify MediPay within 24 hours of confirming an incident), preserving MediPay's own 72-hour and 7-day statutory windows.
2	Default cross-region backup replication risks unannounced data movement	SLA (4.1)	High	Cloud Infrastructure Lead, with DPO	P1 Critical	Before migration go-live	Explicitly disable cross-region replication for all patient/card data services; add a contractual clause prohibiting replication outside the selected region without written consent.
3	Encryption confirmed enabled, but evidence doesn't show a customer-managed key (CMK) in use	Technical evidence (5.1.3, CEK-03)	Medium	Cloud Infrastructure Lead	P2 High	Before go-live	Configure S3/KMS to enforce a MediPay-owned CMK (not the provider default key) via bucket policy, and re-collect the CEK-03 evidence showing a populated KMSMasterKeyID to close this out.
4	No independent audit right, only self-reported STAR/SOC 2	SLA (4.1)	Medium	Legal & Compliance Manager	P2 High	During contract negotiation, before go-live	Add a contractual clause granting MediPay or a third-party assessor the right to a technical/on-site audit. If unobtainable,

							accept ISO/IEC 27001 and SOC 2 Type II as documented interim assurance and record as an accepted residual risk.
5	Production-grade management-plane logging (e.g. CloudTrail) not verifiable in the lab environment	Technical evidence (5.1.5, LOG-07)	Medium	Cloud Infrastructure Lead	P2 High	Before go-live	Confirm and enable the provider's native audit-logging service (CloudTrail or equivalent) in the production account, with log-file integrity validation switched on, since the LocalStack workaround does not represent production coverage.
6	Availability credits capped, don't cover a clinic's lost billing revenue	SLA (4.1)	Medium	Vendor/Contract Manager	P3 Standard	Next contract renewal cycle, within 90 days	Negotiate a service-credit structure tied to business impact or require MediPay to hold separate business-continuity insurance.
7	No certificate of deletion offered at contract exit	SLA (4.1)	Medium	DPO, with Vendor Manager	P3 Standard	Before contract signature; enforced at exit	Require a contractual commitment that the provider issues a signed certificate of deletion, covering primary storage and all backups, within the existing 90-day post-export window.

Prioritisation logic: Gaps 1 and 2 are the only gaps that can cause a statutory breach of the amended PDPA without the occurrence of any security incident and for this reason remain P1. The two gaps that, at this point, were not fully secure, not just in terms of the contract text but also in terms of the technical evidence, are promoted to P2. Gaps 3 and 5 are promoted to P2 ahead of the audit-rights and availability gaps because they are the two points where the technical evidence itself, not just the contract text, stopped short of full assurance. Encryption was confirmed to be enabled but not confirmed to be under MediPay's own control (i.e. a customer-managed key), and logging was demonstrated only via a lab substitute rather than the production-grade service it stands in for.

7.0 Conclusion & Recommendation

7.1 Conclusion

Based on the assessment, MediPay should adopt the proposed public cloud service with conditions. The cloud provider maintains essential security controls which include encryption and access control and logging and tenant isolation systems. The established controls work to defend MediPay's patient information together with their payment card details. The evaluation process discovered multiple deficiencies which require resolution before the system can start operating. The two main gaps are:

1. Breach notification – The SLA does not provide a fixed time for the provider to report a security incident to MediPay. This may make it difficult for MediPay to meet the 72-hour PDPA notification requirement.
2. Data residency – Data may be copied to another region through backup services if cross-region replication is not properly controlled.

Four additional gaps have been identified that pose some risk. Evidence of encryption at rest was available, but it could not be established whether MediPay has control over the key or relies on the provider's default setting. This medium risk will remain until a customer-controlled key has been put in place. Management plane logging has only been demonstrated using a test substitute and not the real audit service. No independent audit can be conducted beyond the provider's STAR and SOC 2 reporting. There is also no certificate of deletion upon the end of the contract period. As such, MediPay lacks documentation that it is compliant or that there has been complete data deletion.

7.2 Recommendation

Recommendation: Adopt with Conditions

MediPay can proceed with the cloud migration, but the following actions must be completed:

Table 6: Recommendation Table

No.	Action	Priority
1	Set a fixed time for the provider to report security incidents.	P1 – Critical
2	Stop unauthorised cross-region data replication.	P1 – Critical
3	Use a MediPay-owned encryption key (CMK).	P2 – High
4	Enable and check production audit logging.	P2 – High
5	Get audit rights or alternative security assurance.	P2 – High
6	Get a deletion certificate for data and backups.	P3 – Standard
7	Improve availability and business continuity.	P3 – Standard

These actions are already included in the remediation plan with **owners, priorities and timelines**.

7.3 Final Decision

The Board needs to approve the cloud migration project after all security requirements and compliance standards reach full compliance.

MediPay needs to solve every P1 Critical and P2 High issue before they can start production operations for their system. The system requires enhancement of breach notification processes while it needs better control mechanisms for data replication between regions, and it must handle customer-managed encryption keys and production audit logging must become possible.

MediPay should not completely reject the cloud provider because the provider already has important security controls and services in place. The organisation needs to solve all discovered security gaps before production starts to decrease its security vulnerabilities and privacy threats and compliance violations.

The recommended decision requires implementation of specific conditions which should form the basis for decision-making. The method lets MediPay achieve its cloud migration goals while it protects patient data and payment card information through appropriate security measures which satisfy all necessary compliance standards.

8.0 References

Payment Card Industry Security Standards Council. (2022). *Payment Card Industry data security standard (PCI DSS): Requirements and testing procedures (Version 4.0)*. [PCI DSS — Official PCI Security Standards Council](#)

Personal Data Protection Commissioner. (2010). *Personal Data Protection Act 2010 (Act 709)*. [Personal Data Protection Act 2010 — Official Malaysian Government source](#)

Personal Data Protection Commissioner. (2024). *Personal Data Protection (Amendment) Act 2024 (Act A1727)*. [Personal Data Protection \(Amendment\) Act 2024 — Official Malaysian Government source](#)

Cloud Security Alliance. (2021). *Cloud Controls Matrix v4*. <https://cloudsecurityalliance.org/artifacts/cloud-controls-matrix-v4/>

9.0 Appendices

9.1 Appendix A - Group Declaration & Peer-Contribution Form

We declare that this assignment is our own work and that all sources have been acknowledged. We confirm the contribution ratings below are a fair reflection of each member's effort.

Table 7: Group Declaration & Peer-Contribution

#	Member name	Student ID	Role / contribution	Peer rating (1–5)	Signature
1	WAN MUHAMMAD AZIM BIN WAN MOHD HAZAN AMRI	52215225024	Section 4 & Section 5	5	<i>Azim</i>
2	SYED ABDULLAH MUBARAK BIN SYED OMAR SHUKRI	52215225160	Section 6	5	<i>Syed</i>
3	SITI KHADIJAH BT AHMAD ZULKIFLE	52215124139	Section 1,2,3 and 8	5	<i>Khadijah</i>
4	NUR BATRISYIA BINTI BAHAROM	52215225343	Board Briefing Note & No. 7	5	<i>Batrisyia</i>

Peer rating scale: 5 = outstanding contribution · 4 = strong · 3 = adequate · 2 = limited · 1 = minimal / none.

9.2 Appendix B - Technical Evidence Pack

```

➔ Assignment git:(main) x ./evidence-collection.sh
MediPay technical evidence pack
Collected: Tue Sep  8 05:23:26 PM UTC 2026 by Syed
=== IAM-05 Least Privilege ===
{
  "RoleName": "patient-lookup-role",
  "PolicyName": "PatientLookupReadOnly",
  "PolicyDocument": {
    "Version": "2012-10-17",
    "Statement": [
      {
        "Effect": "Allow",
        "Action": [
          "s3:GetObject",
          "s3:ListBucket"
        ],
        "Resource": [
          "arn:aws:s3:::medipay-patient-records",
          "arn:aws:s3:::medipay-patient-records/confidential/*"
        ]
      }
    ]
  }
}
=== IVS-06 Segmentation and Segregation ===
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "EnforceTenantIsolation",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::medipay-patient-records/confidential/*",
      "Condition": {
        "StringNotEquals": {
          "s3:ExistingObjectTag/TenantID": "${aws:PrincipalTag/TenantID}"
        }
      }
    }
  ]
}
=== CEK-03 Encryption at rest ===
{
  "ApplyServerSideEncryptionByDefault": {
    "SSEAlgorithm": "aws:kms"
  },
  "BucketKeyEnabled": false,
  "BlockedEncryptionTypes": {
    "EncryptionType": [
      "SSE-C"
    ]
  }
}

```

Figure 1: Screenshot of Evidence Collection

```

=== DSP-04 Data classification ===
{
  "TagSet": [
    {
      "Key": "classification",
      "Value": "confidential"
    }
  ]
}
=== LOG-07 / LOG-02 Management plane audit trail ===
129 mgmt-trail.log
37582de5a17824411a7202ed5a416e150514571380aa8def1f34002018acdbcd mgmt-trail.log
upload: ./mgmt-trail.sha256 to s3://miit-audit-trail/mgmt-trail.sha256
=== AIS-06 Pipeline security gate ===
gate exit code: 0 (0 = policy satisfied, 1 = blocked)
=== DSP-17 Public exposure guardrail ===
{
  "BlockPublicAcls": true,
  "IgnorePublicAcls": true,
  "BlockPublicPolicy": true,
  "RestrictPublicBuckets": true
}
=== DSP-16 Retention and disposal ===
[
  {
    "AutoDelete90Days",
    "Enabled"
  }
]
d0b8a8121bbb7d49c4fa647dfa9dbb6bc5b70b7f3c9a75f133e9a8881496f394 evidence-20260909.txt

```

Figure 2: Continuation Screenshot of Evidence Collection with the SHA256

Evidence Collection

MediPay technical evidence pack

Collected: Mon Sep 7 06:52:24 PM UTC 2026 by Syed

=== IAM-05 Least Privilege ===

```
{
  "RoleName": "patient-lookup-role",
  "PolicyName": "PatientLookupReadOnly",
  "PolicyDocument": {
    "Version": "2012-10-17",
    "Statement": [
      {
        "Effect": "Allow",
        "Action": [
          "s3:GetObject",
          "s3:ListBucket"
        ],
        "Resource": [
          "arn:aws:s3:::medipay-patient-records",
          "arn:aws:s3:::medipay-patient-records/confidential/*"
        ]
      }
    ]
  }
}
```

=== IVS-06 Segmentation and Segregation ===

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "EnforceTenantIsolation",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::medipay-patient-records/confidential/*",
      "Condition": {
        "StringNotEquals": {
          "s3:ExistingObjectTag/TenantID": "${aws:PrincipalTag/TenantID}"
        }
      }
    }
  ]
}
```

=== CEK-03 Encryption at rest ===

```
{
  "ApplyServerSideEncryptionByDefault": {
    "SSEAlgorithm": "aws:kms"
  },
  "BucketKeyEnabled": false,
  "BlockedEncryptionTypes": {
    "EncryptionType": [
      "SSE-C"
    ]
  }
}
```

=== DSP-04 Data classification ===

```
{
  "TagSet": [
```

```

    {
      "Key": "classification",
      "Value": "confidential"
    }
  ]
}
=== LOG-07 / LOG-02 Management plane audit trail ===
105 mgmt-trail.log
upload: ./mgmt-trail.sha256 to s3://miit-audit-trail/mgmt-trail.sha256
=== AIS-06 Pipeline security gate ===
gate exit code: 0 (0 = policy satisfied, 1 = blocked)
=== DSP-17 Public exposure guardrail ===
{
  "BlockPublicAcls": true,
  "IgnorePublicAcls": true,
  "BlockPublicPolicy": true,
  "RestrictPublicBuckets": true
}
=== DSP-16 Retention and disposal ===
[
  [
    "AutoDelete90Days",
    "Enabled"
  ]
]
660f1861367e99b8366da51982d3f89749b4b562be8f306a740efa22c52f94c3 evidence-
20260908.txt

```

9.3 Appendix C - Collection Script

Table 8: Script of Evidence Collection

Bash Script
<pre>#!/usr/bin/env bash # MediPay compliance evidence collection - IKB42603 export EP='--endpoint-url=http://localhost:4566' BUCKET='medipay-patient-records' OUT="evidence-\$(date +%Y%m%d).txt" LS_CONTAINER=\$(docker ps -qf "ancestor=localstack/localstack") { echo "MediPay technical evidence pack" echo "Collected: \$(date -u) by Syed" echo "=== IAM-05 Least Privilege ===" aws \$EP iam get-role-policy --role-name patient-lookup-role --policy-name PatientLookupReadOnly echo "=== IVS-06 Segmentation and Segregation ===" aws \$EP s3api get-bucket-policy --bucket \$BUCKET --query 'Policy' --output text jq . echo "=== CEK-03 Encryption at rest ===" aws \$EP s3api get-bucket-encryption --bucket \$BUCKET \ --query 'ServerSideEncryptionConfiguration.Rules[0]' --output json echo "=== DSP-04 Data classification ===" aws \$EP s3api get-object-tagging --bucket \$BUCKET --key confidential/record.txt echo "=== LOG-07 / LOG-02 Management plane audit trail ===" docker logs "\$LS_CONTAINER" 2>&1 grep -E "AWS [a-z0-9]+\.[A-Za-z]+ =>" > mgmt-trail.log wc -l mgmt-trail.log sha256sum mgmt-trail.log > mgmt-trail.sha256 cat mgmt-trail.sha256 aws \$EP s3 cp mgmt-trail.sha256 s3://miit-audit-trail/ echo "=== AIS-06 Pipeline security gate ===" bash ci-gate.sh > /dev/null 2>&1 echo "gate exit code: \$? (0 = policy satisfied, 1 = blocked)" echo "=== DSP-17 Public exposure guardrail ===" aws \$EP s3api get-public-access-block --bucket \$BUCKET \ --query 'PublicAccessBlockConfiguration' --output json echo "=== DSP-16 Retention and disposal ===" aws \$EP s3api get-bucket-lifecycle-configuration --bucket \$BUCKET \ --query 'Rules[][ID, Status]' --output json</pre>


```
} | tee "$OUT"  
sha256sum "$OUT"%
```